

VULNERABILITY MANAGEMENT FRAMEWORK

Contents

Introduction 2

Personal Vulnerability Management Framework 3

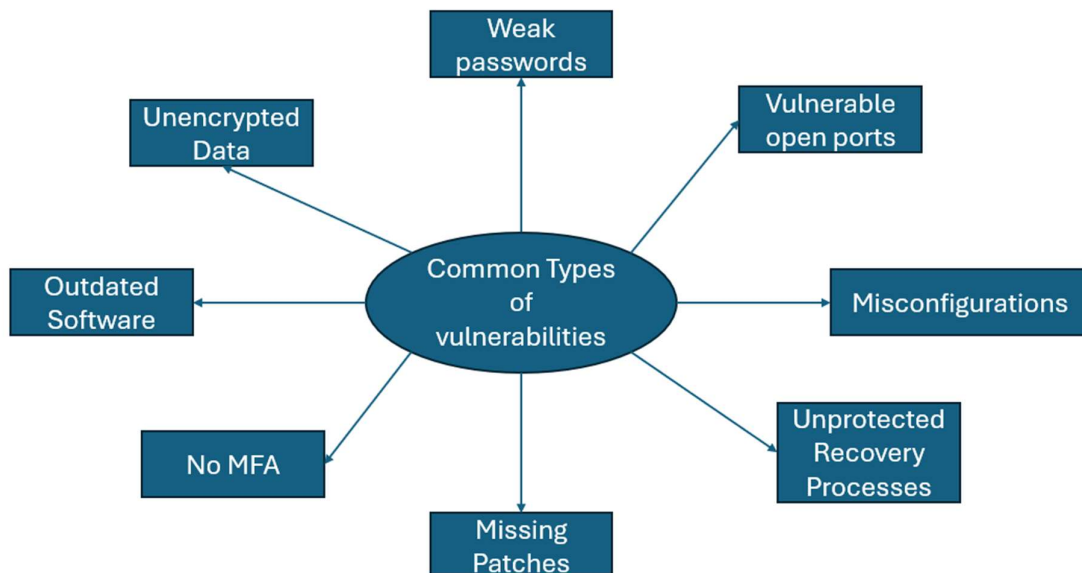
Organisational Vulnerability Management Framework 4

Vulnerability Management Framework Trade-offs 5

Introduction

This vulnerability management framework is designed to help users efficiently and systematically handle vulnerabilities within their systems. This framework can be used by both individuals and organisations. This framework was developed as threat actors commonly exploit known unpatched vulnerabilities within IT systems. Some common vulnerabilities include outdated software and protocols, weak passwords, vulnerable open ports and misconfigurations. This framework is split into personal and organisational usage sections as the processes for these are different. This is because organisations must comply with legal requirements and require more professional responses to vulnerabilities. While individuals do not have to comply with laws such the GDPR or Data Protection Act meaning they are able to use more lightweight structure.

This vulnerability management framework cannot allow users or organisations to find all vulnerabilities within a system as no system is perfect. However, this vulnerability management framework can increase the number of vulnerabilities discovered, patched and documented. Do not trust this vulnerability management framework blindly as it can be wrong. Ensure to adapt the framework's structure to your own security needs and compliance requirements.



The spider diagram above shows the common vulnerabilities within systems seen in both personal and organisational security. It is important to ensure that these vulnerabilities are patched and are reduced within your system where possible. This spider diagram does not show all vulnerabilities or exact misconfigurations in IT systems.

Personal Vulnerability Management Framework

- This section was designed for individual users to discover, path and document vulnerabilities within their own systems.
- I would not recommend using this section for organisation vulnerability management as it isn't designed for that.
- The first step is to calm down.
- This is where you will reduce the emotional noise of any stress, exhaustion or anger you may be experiencing.
- This can be done by taking a few deep breaths or releasing anger in a non-harmful way
- The second step is discovery
- This is where you will locate the vulnerabilities within your account
- This could be done through a password review, daily security check in or just noticing the length of the password in general.
- The third step is Assessing
- This is where you will assess the priority and impact of the vulnerability
- You should ask yourself questions such as what happens if an attacker cracks the password? How easily can my threat model exploit this?
- The fourth step is Patching
- This is where you will fix the vulnerability within your account
- This can be done by changing the password to a 12-16 character generated by a password manager
- You may also turn on MFA on the account if it isn't enabled already
- Make sure to verify that the patch has been applied to the vulnerability
- The fifth step is documenting
- This is where you will document the process of discovering, assessing and patching the vulnerability
- This can be done through the structure What (Weak password) → Domain(Account security) → Why(An attacker could bypass the password to gain unauthorised access to the account) → How(The attacker could use automated tool to crack the password) → Patch(12–16-character password and MFA applied to account) → Potential improvements (What could be improved for next time in the process?)
- This documentation should be stored securely using encryption
- The final step is to repeat the process
- This repetition depends on your threat model.
- For example, for script kiddie every 1-2 months running this process should be efficient.

Organisational Vulnerability Management Framework

- This section is designed for organisations to discover, patch and document vulnerabilities.
- I would recommend not using this section for personal vulnerability management as it will use organisation specific actions and terms.
- This section will use an outdated windows operating system on a company device as the vulnerability.
- Make sure to adapt this section to your needs and resources as each organisation's budget and business operations varies.
- The first step is to identify
- This means discovering the vulnerabilities within the organisation's systems.
- This can be done through Pen testing or automated vulnerability scanning
- The second step is to evaluate
- This means assessing the impact of the vulnerability being exploited on business operations and other metrics
- This also includes prioritizing vulnerabilities which can be done through CVSS and threat modelling
- The third step is to treat the vulnerability
- This includes implementing the correct security measures to fix the vulnerability
- In this case, this can be done by applying a system update to the device and enabling automatic updates
- The fourth step is verification
- This means ensuring that the systems update has been installed with no issues
- This can also include ensuring that there are no new security updates for the Windows operating system.
- This is extremely important as patches must be confirmed as if misconfigured or not done correctly it can cause data breaches later.
- The fifth step is reporting
- This means documenting the process of discovering, assessing and patching the vulnerability
- This can be done using the structure What (Outdated Windows operating system) → Domain (Endpoint protection) → Threat model (Opportunistic attacker and competitors) → Priority (Medium) → Impact (Reputation damage, lawsuits, disruption to business operations) → Patch (Installing latest security update and enabling automatic updates)
- The final step is repeating
- This means repeating the process depending on the threat model your organisation currently has
- For example, for businesses with competitors this could be every month but adapt this as needed.

Vulnerability Management Framework Trade-offs

- This vulnerability management framework has trade-offs just like any other system I have created.
- I have identified 5 main trade-offs with this framework.
- The first trade-off is time-consumption.
- This trade-off exists because users and companies must a decent amount of time discovering, patching and documenting vulnerabilities.
- This means that some users or companies may not be able to manage vulnerabilities effectively as it may be too time-consuming for them to do.
- This trade-off can be managed by automating processes, assigning roles and responsibilities, setting a scheduled time and splitting workload across multiple days to avoid cramping on one day.
- The second trade-off is cost.
- This trade-off exists because users and companies may have to pay for vulnerability detecting tools or tools needed for patching.
- This means that some users or companies may not be able to patch vulnerabilities effectively as it may be too expensive.
- This trade-off can be managed by using built-in security tools, free security software and keeping patches and security features to your threat models.
- The third trade-off is cognitive load
- This trade-off exists because doing this same methodical and systematic process for each vulnerability can be mentally exhausting.
- This means that users and workers in companies may experience high stress or even burn out if they constantly scan their system for vulnerabilities without breaks.
- This trade-off can be managed by automating processes, using priority system for vulnerabilities and robust time management with recovery to prevent burnout.
- The fourth trade-off is complexity.
- This trade-off exists because to discover, patch and document vulnerabilities you require security knowledge to understand what the vulnerability is.
- This means that some users and workers may not be able to manage vulnerabilities not because they aren't capable but because they don't know.
- This trade-off can be managed by automated processes, asking AI model for information and structured learning processes.
- The fifth trade-off is risk of paranoia.
- This trade-off exists because scanning for vulnerabilities can make workers or users constantly question if they missed something.
- This means that some users and workers may burn out or constantly be under stress as they are constantly scanning.
- This trade-off can be managed by setting a schedule for vulnerability scanning & documentation and accepting you can't find every vulnerability within a system.